

Thông tin sinh viên

* Indicates required question

1. Email *

2. 1. Mã sinh viên (In hoa, ví dụ: N23DCAT015). *

Chú ý ghi đúng mã sinh viên để tính điểm, ghi sai sẽ không có điểm

3. 2. Họ và tên (Ví dụ: Nguyễn Văn A) *

4. 3. Lớp (Ví dụ: D23DCAT01-N) *

QUIZ

5. Which solution group does Endpoint Security primarily use to protect user workstations? *

Mark only one oval.

- ☐ Dedicated network traffic routing combined with an intrusion detection system.
- ☐ Web traffic analysis combined with cloud data encryption digital certificates.
- ☐ Anti-malware software, endpoint response systems, and hard drive control.
- ☐ Centralized identity management using biometric authentication at entrance gates.

6. What is the primary purpose of combining firewalls, antivirus software, and data encryption in the Defense in Depth model? *

Mark only one oval.

- ☐ To maximize data retrieval speed from the internal network to the Internet.
- ☐ To force attackers to overcome multiple barriers, minimizing damage if one layer is breached.
- ☐ To help administrators share a single configuration set across all devices to save time.
- ☐ To completely eliminate the need for user authentication since the system automatically identifies them.

7. When an e-commerce platform uses SSL/TLS encryption for the web and installs antivirus software on the server, which security principle are they applying? *

Mark only one oval.

- ☐ Combining the protection of data in transit over the network and data at rest on the server.
- ☐ Focusing resources on building a DMZ to isolate users from the database.
- ☐ Building a DAC authorization system so employees can decide their own security levels.
- ☐ Applying the MAC model to classify security labels for every transaction session.

8. Which service in the access control system is responsible for determining the actions a user is allowed to perform after successfully logging in? *

Mark only one oval.

- ☐ Authentication service verifies the validity of login credentials.
- ☐ Authorization service establishes access limits to resources.
- ☐ Administration service creates, modifies, or deletes user accounts.
- ☐ Auditing service stores system logs for incident investigation purposes.

9. How does the Auditing service provide indirect defense for a financial system? *

Mark only one oval.

- ☐ By immediately locking the account if a user intentionally deletes any file in the system.
- ☐ By recording all valid and abnormal behaviors to trace and detect privilege escalation.
- ☐ By automatically issuing a new digital certificate to users whenever they change their personal password.
- ☐ By configuring the firewall to automatically block traffic from blacklisted countries.

10. A bank employee uses a valid account to illegally download a massive amount of customer credit records. At which step was the system misconfigured? *

Mark only one oval.

- ☐ The identification step, because the system could not distinguish this employee from others.
- ☐ The administration step, because the administrator had not enabled the web application firewall on the database server.
- ☐ The authorization step, because the principle of least privilege was not applied, giving the employee excessive permissions.
- ☐ The encryption step, because the data downloaded to the internal network was not encrypted according to safety standards.

11. Consider the process: Identification -> Authentication -> Authorization. If Admin privileges are mistakenly granted to an intern, even if the first two steps use highly secure biometric technology, what is the consequence? *

Mark only one oval.

- ☐ Advanced verification technology becomes meaningless because the access scope was incorrectly defined.
- ☐ The incident will be automatically blocked by the IDS system upon detecting a sudden role change.
- ☐ The stateful firewall will automatically remove the mistakenly configured access rights.
- ☐ The OTP Token device will stop working until confirmed by the administrator.

12. What is the defining characteristic of the Discretionary Access Control (DAC) model? *

Mark only one oval.

- ☐ The system automatically assigns security labels to all documents regardless of the creator's intent.
- ☐ Resource access rights are entirely decided by the owner of that resource.
- ☐ Only the network administrator has the right to grant file read permissions to employees.
- ☐ Authorization depends on the network address of the device the user is using.

13. How does an Access Control List (ACL) differ from an Access Control Matrix (ACM)? *

Mark only one oval.

- ☐ ACL manages by attaching the list of subjects and corresponding rights directly to each object.
- ☐ ACL maintains a two-dimensional data table containing all subjects currently present on the server.
- ☐ ACL automatically assigns rights to users through predefined job title groups on the Domain.
- ☐ ACL only controls data packets flowing on the network through routing address structures.

14. In the Bell-LaPadula security model, what does the "No Read Up" principle mean? *

Mark only one oval.

- ☐ Copying data from a highly secure environment down to a lower environment is not allowed.
- ☐ Only appending data to documents with a higher security level than one's own clearance is permitted.
- ☐ Reading documents with a security classification level equal to or lower than one's own clearance is permitted.
- ☐ Specialized hardware encryption devices must be used when reading top-secret level data.

15. How does the Role-Based Access Control (RBAC) model apply the "Principle of Least Privilege"? *

Mark only one oval.

- ☐ By automatically and permanently revoking user rights as soon as they log out of the application platform.
- ☐ By granting just enough permissions for a job role, and assigning employees to that role.
- ☐ By requiring the system to continuously monitor the employee's screen to revoke rights upon error.
- ☐ By encrypting files with biometrics to ensure only those with matching fingerprints can decrypt them.

16. What is the biggest difference between Discretionary Access Control (DAC) and Mandatory Access Control (MAC)? *

Mark only one oval.

- ☐ DAC allows users to transfer rights themselves, while MAC imposes rights based on system classification labels.
- ☐ DAC can only be deployed on Linux, while MAC is a mandatory security standard on Windows operating systems.
- ☐ DAC uses asymmetric encryption algorithms, while MAC uses digital certificate systems issued by a third party.
- ☐ DAC manages rights through job title groups, while MAC grants rights based on the connected device's network port.

17. Why is the Access Control Matrix (ACM) rarely used directly in large-scale operating system administration? *

Mark only one oval.

- ☐ Because ACM does not support software execution rights but is limited to reading and writing text.
- ☐ Because the two-dimensional table structure creates too many empty cells, causing massive memory waste.
- ☐ Because every ACM matrix update requires the network server system to be rebooted.
- ☐ Because the matrix scanning algorithm is often mistaken by firewalls as port scanning behavior.

18. A company wants a Project Manager to freely share a source code folder with partners without needing IT intervention. *
Which model should they choose?

Mark only one oval.

- ☐ Mandatory Access Control (MAC) model with statically configured data sensitivity levels.
- ☐ Discretionary Access Control (DAC) model to give full decision-making power to the creator.
- ☐ Bell-LaPadula multilevel security policy combined with a network intrusion detection system.
- ☐ Application Gateway filter model to monitor every file-sharing stream.

19. A software company frequently rotates developers and engineers across different projects. To manage access to project source code and databases most efficiently, which solution should be applied? *

Mark only one oval.

- ☐ RBAC model: create permission groups according to project roles (e.g., Dev, Tester, DevOps) and flexibly assign/remove user accounts from groups upon rotation.
- ☐ DAC model: require the CIO (or System Administrator) to directly configure and approve permissions on each source code folder for each individual.
- ☐ ACM model: hardcode the list of all IT staff permissions for each resource in an access control matrix.
- ☐ Rule-Based model: grant source code access based solely on checking the internal IP address range of the employee's computer.

20. Officer A (Level: Secret) needs to share an operational plan with General B (Level: Top Secret) in a MAC system. Which action is valid? *

Mark only one oval.

- ☐ A writes tactical information into a document labeled Top Secret for B to read.
- ☐ A reads directives in B's Top Secret document to gather information to write a report.
- ☐ A downgrades the document's classification from Secret to Unclassified to email it easily.
- ☐ A creates a Confidential folder, then copies the Secret document into it so B and subordinates can access it.

21. A router is configured to block all HTTP access from IP ranges outside the company. What is this an example of? *

Mark only one oval.

- ☐ Access control based on the delegation of responsibility of each network user.
- ☐ Access control based on the flexible changes of device hardware parameters.
- ☐ Access control based on static rules established according to network packet parameters.
- ☐ Access control through scanning for malware signatures within the transmission traffic.

22. In a healthcare system applying the Biba model to prevent medical record data corruption, what does the "No Write Up" rule prohibit? *

Mark only one oval.

- ☐ Specialist doctors are not allowed to read medical records initiated by interns.
- ☐ Interns are not allowed to edit prescriptions written by Specialist doctors.
- ☐ Doctors voluntarily sharing accounts with interns to have them input data into the system.
- ☐ The system automatically encrypting the database making the board of directors unable to view medical records.

23. Despite using strict DAC, a hacker still retrieves the Director's report by sending disguised malware via email. What is the weakness of DAC here? *

Mark only one oval.

- ☐ DAC automatically downgrades the file's encryption level when accessed via email protocols.
- ☐ The malware, when executed by the Director, inherits all the Director's privileges to bypass all barriers.
- ☐ The ACL's error correction feature automatically changes file permissions when detecting OS anomalies.
- ☐ The hacker exploited a physical vulnerability directly on the server hardware storing the reports.

24. If an ACM Matrix is used to manage permissions for 10,000 employees and millions of files, what technical problem will occur? *

Mark only one oval.

- ☐ Files constantly undergo format structure changes due to the database system's compression algorithm.
- ☐ The "sparse matrix" phenomenon excessively consumes the server's RAM and memory space.
- ☐ The system cannot generate more encryption keys because the variable limit for users is exceeded.
- ☐ The internal fiber optic network becomes congested due to continuously processing validity check algorithms.

25. "Privilege Creep" often occurs when employees transfer across multiple departments in an RBAC system. What is the consequence if left unchecked? *

Mark only one oval.

- ☐ The firewall automatically identifies this account as a malware distribution source and blocks access.
- ☐ The employee possesses too many overlapping permissions, turning the account into a target for hackers.
- ☐ Roles in the system will self-destruct due to algorithmic conflicts between security classification levels.
- ☐ The database stops working because the router cannot handle the volume of one person's permissions.

26. A banking app uses RBAC and OTP. However, a hacker finds a hidden API that allows bypassing the role check step if the OTP is correct. Which service does this flaw belong to? *

Mark only one oval.

- ☐ Administration service, due to not recording the system's authorization actions.
- ☐ Identification service, due to not assigning a unique ID to each session.
- ☐ Authorization service, because the API design missed the access role verification step.
- ☐ Auditing service, because it cannot log connections using security keys.

27. How does Network Segmentation combined with ACLs help overcome the weakness of having only a single perimeter firewall? *

Mark only one oval.

- ☐ Encrypts all data between servers so hackers cannot read it even with physical access.
- ☐ Limits the spread of malware by creating isolated zones with individual controls.
- ☐ Completely replaces user passwords with multi-factor smart card authentication technology.
- ☐ Collects device logs for AI systems to predict future attack trends.

28. How does a hardware token generating OTP codes (like RSA SecurID) operate? *

Mark only one oval.

- ☐ Plugs into a computer USB port to transmit a static 256-bit string straight into temporary memory.
- ☐ Automatically generates a new password after a short time interval, usable only once.
- ☐ Scans the user's fingerprint to create a hash for comparison with the central server database.
- ☐ Blocks access from IPs that were once on the network provider's blacklist.

29. In multi-factor authentication (MFA), which option includes both "Something you have" and "Something you know"? *

Mark only one oval.

- ☐ Logging in with a 16-character password combined with answering a question about personal transaction history.
- ☐ Using a physical Smartcard combined with entering a PIN manually set by the user.
- ☐ High-resolution iris scanning combined with infrared palm vein scanning.
- ☐ Installing a static digital certificate directly onto the desktop browser at the company headquarters.

30. In a Public Key Infrastructure (PKI), what is the role of the "CA Signature" on the certificate? *

Mark only one oval.

- ☐ Ensures the public key in the certificate truly belongs to the issued entity and has not been altered.
- ☐ Encrypts all data transmitted between the storage server and the user's web browser.
- ☐ Provides a platform for automatic facial recognition of users accessing commercial websites.
- ☐ Prioritizes packets carrying certificates to pass through the core firewall without inspection.

31. What is the biggest disadvantage making biometric identification (fingerprint, iris) harder to apply widely for millions of customers compared to passwords? *

Mark only one oval.

- ☐ Biometric data changes continuously over the day, making scanners unable to match them.
- ☐ High hardware costs, involves error rates (FAR/FRR), and if data is compromised, it cannot be changed.
- ☐ Biometric analysis algorithms cause massive bandwidth delays when transmitting over the OSI network model.
- ☐ International routing systems often refuse to transmit high-resolution image data packets.

32. To defend against password Sniffing and Replay Attacks, what solution should a financial institution use? *

Mark only one oval.

- ☐ Require customers to change their password daily with rules for uppercase, numbers, and special characters.
- ☐ Abandon the web interface entirely and route all transactions through ATM systems with surveillance cameras.
- ☐ Switch to using an OTP generation application (Soft Token) on the user's mobile device.
- ☐ Install a Signature-based IDS on the administration server.

33. A company needs to set up a VPN for remote workers. Which solution best prevents Brute-force attacks while optimizing costs? *

Mark only one oval.

- ☐ Issue Smartcards to each person and buy card readers to attach to personal computers.
- ☐ Use Google Authenticator (OTP) combined with existing internal login accounts.
- ☐ Install infrared iris scanners at the home workstations of every remote employee.
- ☐ Apply an AI-generated 10-layer security question system every time the VPN starts.

34. Although a Smartcard with a PIN is very secure, how can a hacker still gain access without physically stealing the card? *

Mark only one oval.

- ☐ Sending millions of Ping packets to the firewall to bottleneck the PIN authentication stream.
- ☐ Infecting the victim's computer with malware to extract the key temporarily stored in RAM while the card is plugged in.
- ☐ Spoofing the ARP protocol on the Switch to force the server to automatically invalidate the card's certificate.
- ☐ Exploiting physical vulnerabilities on the server to modify the statically stored PIN hash.

35. When setting a facial recognition machine's sensitivity level too high, what will happen? *

Mark only one oval.

- ☐ The False Acceptance Rate (FAR) approaches 0 ensuring safety, but the False Rejection Rate (FRR) increases causing inconvenience.
- ☐ Both FAR and FRR decrease to the lowest level, helping optimize transmission bandwidth.
- ☐ The system automatically switches to network anomaly analysis mode to search for spyware.
- ☐ The False Acceptance Rate (FAR) spikes because the system is overwhelmed by the volume of high-quality pixels.

36. Regarding information security, what is the biggest vulnerability of using SMS messages to receive OTP codes (OTP SMS)? *

Mark only one oval.

- ☐ SMS is plain text easily cracked by port scanning tools on computers.
- ☐ The SMS delivery process over telecom networks is often not end-to-end encrypted and easily intercepted.
- ☐ SMS stored on phones will infect the mobile operating system with Ransomware.
- ☐ The algorithm generating OTP via SMS conflicts with the firewall's network application policies.

37. What problem does using Single Sign-On (SSO) combined with digital certificates solve for internal enterprises? *

Mark only one oval.

- ☐ Enhances malware scanning capability during downloads and speeds up line encryption.
- ☐ Reduces the risk of employees setting weak passwords from memorizing multiple accounts, and allows easy centralized revocation.
- ☐ Distributes system traffic to avoid direct Denial of Service attacks on servers.
- ☐ Restructures complex ACM matrices into ACL lists integrated directly into the Router.

38. How does the "Default Deny" principle work on an edge firewall? *

Mark only one oval.

- ☐ Temporarily locks IP addresses with traffic exceeding the system's allowed bandwidth threshold.
- ☐ Any network connection not explicitly on the allowed (Allow) rules list is automatically blocked.
- ☐ Packets originating from the Internet are blocked, while connections from inside to outside pass freely.
- ☐ The firewall will close service ports if it cannot verify a valid encryption certificate.

39. What problem does a DMZ zone created by two independent firewalls aim to solve? *

Mark only one oval.

- ☐ Creating an unencrypted network segment to maximize the company's internal data download speed.
- ☐ Placing public servers (Web, Mail) in an intermediate zone to prevent hackers from spreading directly into the LAN.
- ☐ Providing a training environment for anomaly analysis systems to identify new malware.
- ☐ Merging physical access control via smartcards and network control into a single server.

40. What is the main reason a Hardware Firewall processes traffic better than a Software Firewall? *

Mark only one oval.

- ☐ Hardware firewalls use advanced AI algorithms to automatically configure network routing rules.
- ☐ Hardware firewalls use Application-Specific Integrated Circuits (ASICs) specifically optimized for high-speed packet filtering.
- ☐ Hardware firewalls are not limited by the number of physical connection ports to the switching center.
- ☐ Software firewalls cannot monitor the TCP connection establishment handshake process.

41. In a DMZ model, what is the risk of placing a Database Server (containing customer data) alongside the Web Server in the DMZ? *

Mark only one oval.

- ☐ The Database Server cannot answer queries from the LAN due to the firewall blocking loopback connections.
- ☐ The DMZ is a risky zone directly facing the Internet; placing sensitive data here violates the principle of separation of domains.
- ☐ Data written to the database gets formatted incorrectly due to the firewall's packet inspection algorithm.
- ☐ The routing device's cache overflows when the volume of external database connections suddenly increases.

42. If the Default Deny (Deny Any) rule is accidentally placed at the top of the firewall's rule list, what will happen? *

Mark only one oval.

- ☐ The firewall reports a syntax error and automatically moves this rule to the bottom to continue running.
- ☐ All network connections are blocked immediately, paralyzing the system because every packet matches the first rule.
- ☐ The firewall forwards all suspicious traffic to the IDS system for malicious behavior analysis.
- ☐ Encrypted data streams pass normally; only plaintext packets are blocked.

43. 2-Firewall Model: Internet FW allows access to the Web Server in the DMZ. Internal FW allows the Web Server to access * the Database in the LAN. If a hacker compromises the Web Server, what happens next?

Mark only one oval.

- ☐ The hacker is completely blocked because the Internal FW isolates independent data streams blocking unauthorized commands.
- ☐ The hacker uses the Web Server as a valid Pivot to attack the Database directly through the open port.
- ☐ The system automatically cuts power to the Database when seeing a sudden spike in external queries.
- ☐ The 2-firewall model automatically switches to a static state waiting for infosec personnel to fix it.

44. A Next-Generation Firewall (NGFW) combines multiple features (Stateful, IPS, AV) into one device. What is the biggest * architectural weakness of this design?

Mark only one oval.

- ☐ It turns the device into a Single Point of Failure (SPOF); if the hardware overloads, the entire internal network collapses.
- ☐ The device will disable virtualized cloud access streams, making the company unable to retrieve distributed data.
- ☐ It forces the organization to abandon the RBAC model to yield control to the central system.
- ☐ It requires continuously restarting personal computers to update the multi-layer firewall's routing parameters.

Google Forms